



AI面接インタビューシステム

Day 16 報告書

プロジェクト: AI面接インタビューシステム

フェーズ: Phase 4 — 本番セキュリティ強化・管理画面テスト

対象: Day 16 (Rack::Attackレート制限・Admin/Clientテスト)

作成日: 2026-03-20

フレームワーク: Ruby on Rails 6.1.7 / Ruby 3.1.6

目次

Day 16: Rack::Attackレート制限導入・Admin/Clientテスト

1. 概要

2. Rack::Attack レート制限導入

3. レート制限テスト（10テスト）

4. Admin::InterviewResults テスト（7テスト）

5. Client::InterviewResults テスト（6テスト）

まとめ

6. テスト結果サマリー

7. 変更ファイル一覧

Day 16: Rack::Attackレート制限導入・Admin/Clientテスト

1. 概要

本番環境のセキュリティ強化として**Rack::Attack**によるAPIレート制限を導入。併せて未テストだった**Admin/Client管理画面コントローラー**のテストを追加し、認証・認可の網羅的な検証を実現した。テスト総数は292→316（+24テスト）となり、全件パスを確認した。

316

テスト全件パス

+24

新規テスト追加

6

レート制限ルール

429

API保護レスポンス

2. Rack::Attack レート制限導入

項目	内容
Gem	rack-attack 6.8.0
設定ファイル	config/initializers/rack_attack.rb
キャッシュ	ActiveSupport::Cache::MemoryStore（本番ではRedis推奨）

レート制限ルール一覧

ルール	対象	制限	目的
api/global	/api/* 全体	60 req/min/IP	API全体の保護
api/interviews/start	POST /start	10 req/min/IP	面接乱用防止
api/interviews/start_by_token	POST /start_by_token	20 req/min/IP	トークン総当たり防止
api/interviews/submit_answer	POST /submit_answer	30 req/min/IP	アップロード制限
api/interviews/complete	POST /complete	10 req/min/IP	完了乱用防止
auth/login	Devise sign_in	10 req/min/IP	ブルートフォース防止

セキュリティ機能

- **ホワイトリスト**: localhost (127.0.0.1, ::1) は制限除外
- **ブロックリスト**: ENV['BLOCKED_IPS'] で明示的なIP拒否
- **429レスポンス**: JSON形式 + Retry-After, X-RateLimit-* ヘッダー
- **403レスポンス**: ブロックIPに対するJSON形式レスポンス

3. レート制限テスト (10テスト)

ファイル: spec/requests/api/rate_limiting_spec.rb

カテゴリ	テスト数	内容
API全体レート制限	2	制限内OK、制限超過429
面接開始レート制限	2	10回内OK、11回目429
トークン開始レート制限	1	21回目429
429レスポンスフォーマット	3	JSON形式、Retry-After、X-RateLimitヘッダー
IPブロックリスト	1	ブロックIP→403
localhostセーフリスト	1	セーフリスト時制限なし

4. Admin::InterviewResults テスト (7テスト)

ファイル: spec/requests/admin/interview_results_spec.rb

カテゴリ	テスト数	内容
GET /admin/interview_results	5	Admin認証OK、複数結果表示、未認証リダイレクト、Client認証拒否、User認証拒否
GET /admin/interview_results/:id	2	詳細表示OK、存在しないID 404

5. Client::InterviewResults テスト (6テスト)

ファイル: spec/requests/client/interview_results_spec.rb

カテゴリ	テスト数	内容
GET /client/interview_results	3	Client認証OK、未認証リダイレクト、User認証拒否
GET /client/interview_results/:id	3	自分の結果OK、他Clientの結果RecordNotFound、未認証リダイレクト

認可テスト: Client間のデータ分離を確認。Client AがClient Bの面接結果にアクセスすると ActiveRecord::RecordNotFound (where(client_id: current_client.id)フィルタリングによる保護)。

まとめ

6. テスト結果サマリー

96

Day 13

254

Day 14

292

Day 15

316

Day 16

7. 変更ファイル一覧

新規作成ファイル（5件）

`config/initializers/rack_attack.rb`

Rack::Attack レート制限設定

`spec/requests/api/rate_limiting_spec.rb`

レート制限テスト（10テスト）

`spec/requests/admin/interview_results_spec.rb`

Admin管理画面テスト（7テスト）

`spec/requests/client/interview_results_spec.rb`

Client管理画面テスト（6テスト）

`spec/factories/admins.rb`

Admin Factory

修正ファイル（1件）

ファイル	変更内容
Gemfile	rack-attack gem追加

Day 16 完了: Rack::Attackレート制限導入（6ルール）、Admin/Clientテスト追加。テスト数292→316（+24）。全316テストがパス。